

Tome — Open-Source Adoption Council Report

Date: 2026-08-09 · **Audience:** tech leads evaluating Tome for their teams

Method: seven-expert council review of README, THREATMODEL.md, the UX council report, both prior code reviews (pi 8.0/10, Kimi K3), IMPROVEMENTS-PLAN/STATUS, the flows feature plan, and `package.json`. Framing question for every seat: "I'm a tech lead. My engineers already have Claude Code / Cursor / Copilot. Why would I champion this — and what would make me walk away?"

Verdict: Tome has a genuinely differentiated position — **the governance plane for agent CLIs** (per-pane air gap, seatbelt sandboxing, human-gated conductor) — and a real story for AI adoption in B2B SaaS, where shadow AI is now the top blocker. But the repo under-sells it: the README leads with window management, there are no releases, no CI badge, no CONTRIBUTING, and macOS-only + unsigned builds cap the champion motion. The moat is policy-as-product; the gap is trust surface and packaging.

■ E1 — AI Adoption Strategist (B2B SaaS) — ■ thesis / ■ execution

The strongest finding of the council. Every B2B SaaS org in 2026 has the same problem: engineers adopted agent CLIs bottoms-up, security found out later, and now there's a spreadsheet of un-audited API keys and unsanctioned tools. Tome's air gap is the **only shipping answer** to "how do I let my team run Claude Code without it being able to `curl` my source to anywhere on the internet."

- **■ The wedge is governance, not productivity.** "Agents, terminals, editors and chat in one grid" is a Cursor-adjacent pitch and loses. "Run any agent CLI behind a per-pane egress allowlist enforced by the macOS seatbelt, with a second factor to open the pipe" has no competitor. Lead with it.
- **■ Agent-agnostic is an adoption superpower.** Claude Code, opencode, pi light up on PATH with no config — Tome rides every model wave instead of betting on one. For a tech lead standardizing a team, that means the tool survives the next model switch.
- **■ The buyer and the user are different people.** The champion is an IC engineer; the *approver* is the tech lead, and the *blocker* is security. The README speaks only to the champion. Add a `docs/SECURITY.md` aimed at the blocker (THREATMODEL.md is excellent but reads like maintainer notes, not an evaluation artifact).
- **■ No audit trail.** Governance buyers ask "what did the agent do?" Tome has scrollbar but no structured log of conductor tool calls, unlock events, or blocked-egress attempts. The blocked-host flash vanishes in 4 s (UX council caught this too). A persistent, exportable event log converts the air gap from a feature into *evidence*.
- **■ Flows are the team story.** A committed `.flow.json` is a code-reviewable multi-agent pipeline — that's the artifact a tech lead puts in a design doc. It's buried mid-README. It belongs in the hero.

■ E2 — Dev-Tools Product Manager — ■

- **■ Clear ICP:** senior IC / tech lead at a 20–500 person SaaS company, macOS-heavy eng org, already paying for agent CLIs, nervous about data egress. That's a real, reachable niche.
- **■ Zero onboarding path for a team.** Workspaces, flows, air-gap allowlists are all per-machine. The first thing a tech lead wants is "commit a recommended Tome config to the repo so my team gets the same setup." `.tome/flows/` proves you already think this way — extend it: workspace definitions and allowlists as committable files.
- **■ The conductor's default-off auto-run is the right product call** and should be marketed: "the assistant proposes, you dispose." It's the anti-Cursor sentiment capture.

- ■ **Docs assume discovery.** Glyph iconography (■ ■ ■) was flagged by the UX council; for adoption it's worse — a tech lead's 10-minute evaluation never finds tear-off windows or per-group tabs. The interactive [docs/how-tome-works.html](#) is the best onboarding asset you have; link it from the README's first screen.
- ■ Naming/packaging: `v0.1.0`, `private: true`, no GitHub releases. Version optics matter less than *installability* — see E5.

■ E3 — Security Engineer (the approver) — ■ core / ■ surface

Reviewed THREATMODEL.md against both prior code reviews. This is the strongest part of the project.

- ■ **The load-bearing invariants are correct and well-chosen:** proxy-widens-never-sandbox, lock-gate wrapping `ipcMain.handle` (fail-closed by construction), vetted pane kinds, conductor auto-run guard in main with control-char stripping (verified by pi against the regex), second-factor pane unlock. Two independent reviewers landed at 8/10. That is a *marketable* fact: "two independent council reviews, findings tracked in [docs/IMPROVEMENTS-STATUS.md](#)."
- ■ **The confused-deputy loop is named and capped.** Scrollback→model→tool-call is the exact attack every security team worries about with agent tools; having a written, bounded answer (ANSI-stripped scrollback, 8-turn cap, human-gated submit) puts Tome ahead of tools that haven't thought about it at all.
- ■ **Unsigned builds kill the enterprise motion.** `identity: null` means Gatekeeper blocks the app; a tech lead cannot hand an unsigned binary to their security team with a straight face. Ad-hoc signing + notarization is table stakes for the ICP. Until then, document `xattr -dr com.apple.quarantine` in the README — silence reads as naivety.
- ■ **TOME_SHOT auth bypass** is gated on `!app.isPackaged` per WS2 — confirm it shipped (IMPROVEMENTS-STATUS says complete; keep it verifiable in CI).
- ■ **Supply-chain notes exist but are scattered** (SheetJS CDN pin is documented in THREATMODEL §7 — good). Add a CI provenance story: build workflow that produces the release artifacts so "the binary matches the repo" is checkable.
- ■ **TOTP secret at rest:** WS2 planned `safeStorage` encryption — confirm status; it's the kind of line item a security review checklist asks about directly.

■ E4 — Staff Engineer / Tech Lead (the champion) — ■

The persona this whole report is for. Simulated evaluation: *clone, 10 minutes, decide whether to pilot with two engineers for a week.*

- ■ **"Real PTY, login shell, your prompt, your keybindings"** — this sentence sells to exactly me. No re-learning, no Electron-terminal weirdness. Keep it verbatim in the hero.
- ■ **The conductor is the daily-driver feature.** "What is claude doing in the other pane?" / "run the tests over there" — cross-pane awareness is the thing tmux + 4 terminal windows can't do. The human-gated submit makes it trustworthy enough to leave on.
- ■ **I can't install it.** No releases, no Homebrew cask, no `npm i -g`. My evaluation starts with `npm install && npm run package` and an unsigned-app warning. Every other tool I evaluate this quarter installs in one command. This is the single highest-leverage fix in the report.
- ■ **macOS-only halves my team.** I know seatbelt is the point, but say the quiet part in the README: "macOS first; Linux via bwrap/namespaces is design-compatible" (the proxy-not-sandbox architecture genuinely does port — the allowlist proxy is platform-neutral). Otherwise I assume it's a personal project and move on.

- ■ **228 tests, CI workflow, threat model, two independent reviews** — the maturity signals exist but are invisible from the README. A badges row (CI, tests, license) and a "Project maturity" section would do disproportionate work.
- ■ Electron memory footprint with 6+ ptys — someone will ask. One line in docs ("measured ~X MB with N panes") preempts the HN thread.

■ E5 — Open-Source Strategy — ■

- ■ MIT license — right call for bottoms-up dev-tool adoption; no hesitation there.
- ■ **"private": true in package.json** while calling it open source — trivial fix, but it signals the repo isn't ready for the public. Same for the missing pieces: no **CONTRIBUTING.md**, no issue templates, no **CODE_OF_CONDUCT**, no roadmap. A tech lead evaluating *dependence* on a solo-maintainer project looks at exactly these to judge bus factor.
- ■ **Distribution is the open-source product.** Homebrew cask (`brew install --cask tome`) is the install path this audience trusts; it also forces the signing/notarization fix (E3), killing two findings with one pipeline.
- ■ **The moat is policy, and policy wants to be data.** Today the air-gap allowlist is per-machine JSON in `userData`. If it becomes a committable, shareable format (`.tome/airgap.json` in-repo, org presets on GitHub), Tome gains a network effect no pane-layout feature can produce: teams publishing their allowlists. That's the open-core-adjacent move that stays honest — the policy *engine* stays MIT; hosted policy *distribution* is the eventual business if you want one.
- ■ **Community surface:** the flows format (`.flow.json`) is shareable by design — a `tome-flows` examples repo is cheap community fuel and demonstrates the conductor story better than any screencast.
- ■ Release cadence: even monthly tags with changelogs signal life. The git history shows intense development; the public surface shows none of it.

■■ E6 — Competitive Analyst — ■

Tool	What it is	Tome's angle
Cursor / VS Code + Copilot	Editor-first, single-model, cloud-routed	Tome is agent-agnostic and local-first; no editor lock-in
Claude Code / opencode / pi (bare CLI)	One agent, one terminal, full network access	Tome wraps <i>any</i> of them in egress policy + orchestration
Warp	Modern terminal, AI features, their cloud	Tome: real PTYs, your shell, no account, air gap
tmux + iTerm	The actual incumbent	Conductor (cross-pane awareness) + flows (repeatable graphs) + editors/docs in-grid
Zed	Fast editor, collab focus	Different category; Tome is a harness, not an editor

- ■ **Defensible niche:** nobody else combines (a) agent-agnostic PTY hosting, (b) per-pane egress enforcement, (c) a human-gated orchestrating assistant, (d) committable multi-agent graphs. Any two exist somewhere; all four don't.
- ■ **Category risk:** if Anthropic/OpenAI ship first-party sandboxed team offerings, the governance wedge narrows. Mitigation is speed + the policy-as-data moat (E5) + being the Switzerland layer when teams run 2–3 agent CLIs at once (they do).
- ■ **"Harness" is not a category anyone searches for.** The README's first line should name the job: "Run your coding agents behind an air gap, in one workspace." Let the word *harness* appear later.

- ■ Watch: VS Code's agent-hosting APIs and Warp's team features — both are one release away from nibbling the wedge.

■ E7 — Developer Relations — ■

- ■ **The assets are unusually good:** [how-tome-works.html](#) is a better launch artifact than most funded startups produce; the screenshot is honest; the threat model is a credibility weapon with the security-conscious slice of this audience.
- ■ **The README buries the lede.** Current order: workspaces → panes → appearance → editor → ... → air gap near the bottom. The evaluation order of a tech lead is: *what is it* → *why should I trust it* → *how do I install it* → *what does it cost my team*. Reorder: hero line (governance + harness) → 30-second screenshot/GIF of the air gap blocking egress → install → the conductor demo → then features.
- ■ **One demo beats ten bullets.** The killer 60-second clip: spawn claude in an air-gapped pane, watch it fail to reach a non-allowlisted host, unlock with Touch ID + TOTP, watch the conductor ask the other pane what it's doing. Every element of the moat in one take.
- ■ **Launch sequencing:** Show HN with the threat model + air-gap story (security angle travels), *not* with "another AI IDE." *r/commandline* and the Claude Code/opencode communities are warmer first audiences than *r/programming*.
- ■ The name "Tome" + the ■ glyph identity is distinctive and thematically coherent (bound workspace, spellbook) — keep it, but make the tagline do the explaining.

Consensus roadmap — ranked by adoption impact per effort

#	Pri	Item	Seats	Effort
1	■ P0	Signed + notarized builds, GitHub releases, Homebrew cask	E3 E4 E5	M
2	■ P0	README reorder: governance hero → air-gap demo → install → conductor → features; badges row	E4 E6 E7	S
3	■ P0	SECURITY.md (evaluation-facing, from THREATMODEL.md) + CONTRIBUTING.md + issue templates; flip <code>private: true</code>	E5 E3	S
4	■ P1	Committable team config: <code>.tome/</code> workspace + air-gap allowlist checked into the repo	E1 E2 E5	M
5	■ P1	Persistent, exportable event log: conductor tool calls, unlocks, blocked egress	E1 E3	M
6	■ P1	60-second air-gap demo clip + flows example repo	E7 E5	S
7	■ P1	Linux statement in README (design-compatible, proxy ports, sandbox TBD)	E4 E6	XS
8	■ P2	Policy-as-data: shareable allowlist presets, org distribution story	E5 E1	M
9	■ P2	CI-built release artifacts (binary matches repo) + release cadence	E3 E5	M
10	■ P2	Memory/perf one-pager; footprint with N ptys	E4	S

Summary: Tome's engineering credibility is already where it needs to be — two independent 8/10 reviews, a real threat model, 228 green tests. What's missing is everything *around* the code that lets a tech lead stake their credibility on it: an installable signed artifact, a README that leads with the governance wedge, and team-shareable policy. Ship P0 and the air gap does the marketing.